

**Министерство науки и высшего образования Российской Федерации  
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ  
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ  
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

**Факультет безопасности информационных технологий**

**Дисциплина:**

«Проектирование комплексных систем защиты информации»

**ОТЧЕТ ПО ПРАКТИЧЕСКИМ РАБОТАМ**

«Проект комплексной системы защиты информации предприятия “MedCare”»

**Выполнили:**

Чу Ван Доан, студент группы N3447



Чан Бао Линь, студентка группы N3446



Доан Тхи Хоай Тхыонг, студентка группы N3445



**Проверил:**

Коржук Виктория Михайловна,

к.т.н., доцент ФБИТ

\_\_\_\_\_  
(отметка о выполнении)

\_\_\_\_\_  
(подпись)

Санкт-Петербург

2025г.

## СОДЕРЖАНИЕ

|                                                                                    |    |
|------------------------------------------------------------------------------------|----|
| Содержание                                                                         | 2  |
| 1. Общие положения                                                                 | 4  |
| 1.1. Общие сведения о защищаемой организации                                       | 4  |
| 1.2. Цель разработки КСЗИ                                                          | 6  |
| 2. Предпроектное исследование организации (до внедрения мер)                       | 8  |
| 3. Предпроектное исследование организации (до внедрения мер)                       | 10 |
| 3.1. Модель нарушителя                                                             | 10 |
| 3.2. Модель угроз                                                                  | 12 |
| 3.3. Предварительная оценка рисков                                                 | 22 |
| 4. Требования по защите информации в организации                                   | 28 |
| 4.1. Требования по защите информации сформулированы на основе следующих документов | 28 |
| 4.2. Учтенные при разработке требования руководящих документов                     | 29 |
| 5. Техническое задание на разработку КСЗИ (часть)                                  | 31 |
| 5.1. Общие сведения                                                                | 31 |
| 5.2. Цели создания СЗПДи                                                           | 31 |
| 5.3. Характеристика объекта защиты                                                 | 32 |
| 5.4. Расположение объекта информатизации                                           | 32 |
| 5.5. Техническое решение по созданию СЗПДн                                         | 33 |
| 5.5.1. Этап создания СЗПДн                                                         | 33 |
| 5.5.2. Требования к режимам функционирования системы                               | 33 |
| 5.5.3. Требования к надежности                                                     | 34 |
| 5.5.4. Требования безопасности                                                     | 34 |
| 5.5.5. Требования к квалификации исполнителя                                       | 35 |
| 6. Предлагаемые меры и средства по защите информации в организации                 | 37 |
| 6.1. Организационно-правовая защита информации                                     | 37 |
| 6.2. Программно-аппаратная защита информации                                       | 38 |
| 6.3. Инженерно-техническая защита информации                                       | 40 |
| 6.4. Технические средства охраны                                                   | 42 |
| 6.5. Криптографическая защита                                                      | 49 |
| 6.6. Общая стоимость КСЗИ                                                          | 51 |
| 7. Оценка эффективности предложенных мер                                           | 52 |
| ЗАКЛЮЧЕНИЕ                                                                         | 59 |

## СОКРАЩЕНИЯ

|       |   |                                                        |
|-------|---|--------------------------------------------------------|
| АРМ   | – | автоматизированное рабочее место                       |
| ГОСТ  | – | государственный стандарт                               |
| АСО   | – | активное сетевое оборудование                          |
| АСУ   | – | автоматизированная система управления                  |
| ИБ    | – | информационная безопасность                            |
| ИБП   | – | источник бесперебойного питания                        |
| ИС    | – | информационная система                                 |
| ЛВС   | – | локальная вычислительная сеть                          |
| ТП    | – | технологический процесс                                |
| ТС    | – | техническое средство                                   |
| УБИ   | – | угрозы безопасности информации                         |
| ИСПДн | – | информационная система персональных данных             |
| ПДн   | – | персональные данные                                    |
| СЗИ   | - | средства защиты информации                             |
| СЗПДн | - | система защиты персональных данных                     |
| ТЗ    | - | техническое задание                                    |
| ФСБ   | - | федеральная служба безопасности                        |
| ФСТЭК | - | федеральная служба технического и экспортного контроля |
| ОРД   | - | организационно-распорядительной документации           |

## **1. ОБЩИЕ ПОЛОЖЕНИЯ**

Представленный отчет содержит технические решения по созданию комплексной системы защиты информации организации MedCare.

### **1.1. Общие сведения о защищаемой организации**

Наименование организации: ООО «MedCare»

Область деятельности:

Основными видами деятельности компании являются медицинское обследование, лечение и медикаментозное обеспечение пациентов.

Прибыль (месячная/годовая), расходы, стоимость информационных активов:

- прибыль: 3 500 000 руб./месяц;
- расходы: 5 500 000 руб./месяц, включая
  - общий фонд оплаты труда: 2 600 000 руб./месяц;
  - налоги: 800 000 руб./месяц;
  - лекарства и медицинские изделия: 1 400 000 руб./мес;
  - аренда, коммунальные платежи: 700 000 руб./месяц.

Персонал организации (33 человек): 1 Директор, 2 заместители директора, 1 бухгалтер, 10 врачи, 10 медсестры, 7 административный персонал и технические специалисты (отдел ИБ, отдел анализа данных), 2 охранника.

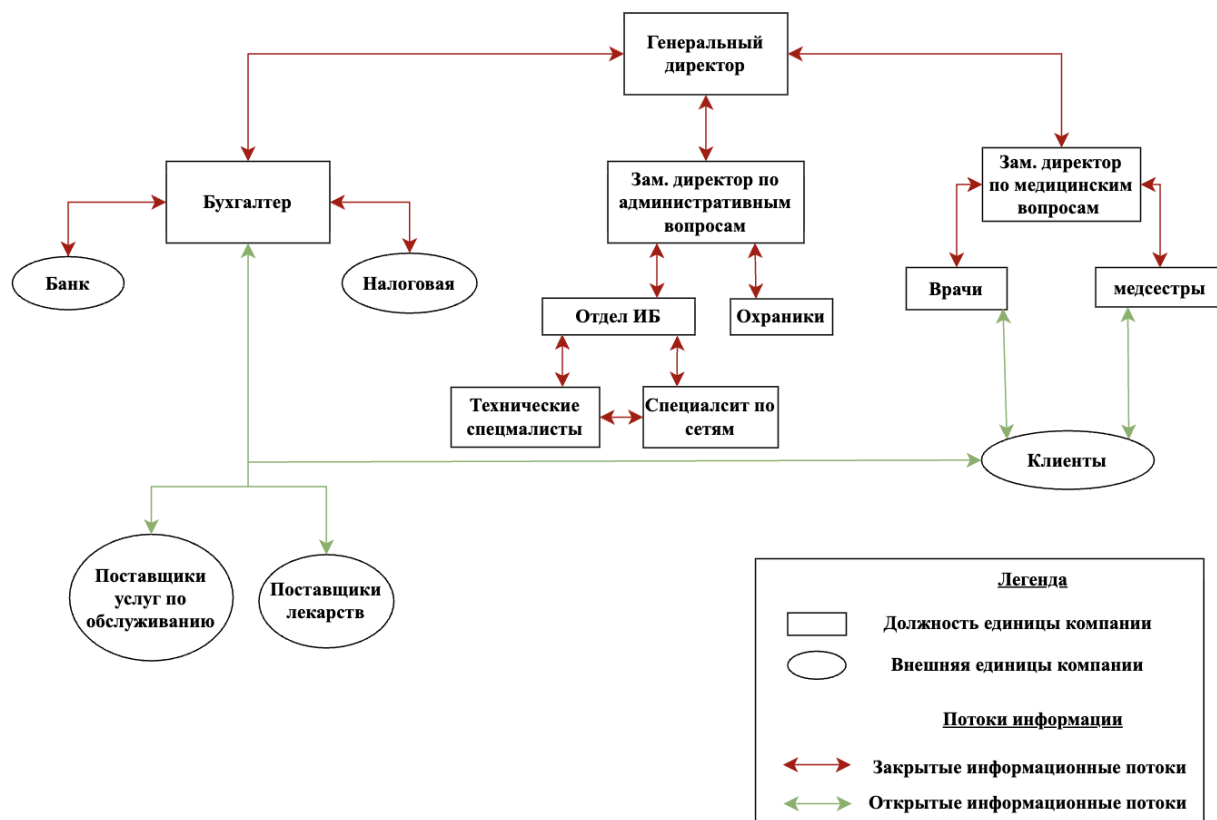


Рисунок 1 – Информационные потоки между отделами предприятия и структура предприятия

План помещения: 2 этажа (отдел ИБ, ресепшн, бухгалтерия, переговорная, столовая, охрана, клиника, туалет, зал ожидания, северная, кабинет зам. Директора, кабинет директора).SS

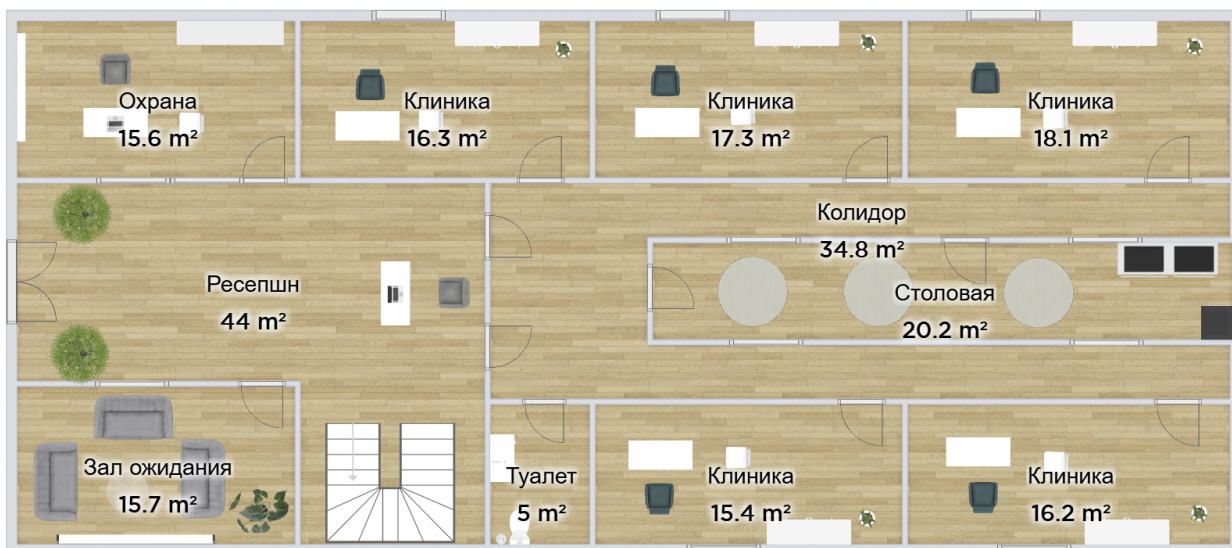


Рисунок 1 - Первый этаж



Рисунок 2 – Второй этаж

## 1.2.Цель разработки КСЗИ

Целью создания КСЗИ является обеспечение устойчивого функционирования организации «MedCare» при проведении в отношении него компьютерных атак:

1. Влияние на пользователей, администраторов безопасности, администраторов информационных систем или обслуживающий персонал;
2. Несанкционированный доступ и (или) воздействие на объекты на аппаратном уровне;
3. Несанкционированное копирование и (или) изменение информации на компьютерных носителях информации;

4. Несанкционированный доступ и (или) воздействие на линии (каналы) связи, технические средства, носители информации ЭВМ;
5. Несанкционированный доступ и (или) воздействие на объекты на системных уровнях.

## 2. ПРЕДПРОЕКТНОЕ ИССЛЕДОВАНИЕ ОРГАНИЗАЦИИ (ДО ВНЕДРЕНИЯ МЕР)

Предприятие ООО «MedCare» предназначено для выполнения функций медицинского осмотра и ухода за пациентами

В состав ЛВС Предприятия ООО «MedCare» входят следующие системы:

- информационная система;
- автоматизированная система управления (АСУ) технологическим процессом.

АСУ ТП выполняет информационные, управляющие, контролирующие и регулирующие функции, обеспечивая контроль состояния технологического оборудования Предприятия и его защиту при возникновении нештатных ситуаций

ИС включает в свой состав:

- средства вычислительной техники (СВТ);
- активное сетевое оборудование (АСО);
- каналы передачи данных;
- программное обеспечение (ПО).

Оборудование ИС организации включает в себя:

- СВТ (35 автоматизированных рабочих мест (АРМ), 5 серверов и 15 (мобильных АРМ). Перечень СВТ организации представлен в таблице 1;

Таблица 1 – Перечень СВТ организации

| Наименование СВТ     | Аппаратная платформа | Версия операционной системы (ОС) | Средство защиты информации (СрЗИ) |
|----------------------|----------------------|----------------------------------|-----------------------------------|
| АРМ 1 - 35           | x86-64               | Microsoft Windows 10 64-Bit      | Windows Defenders                 |
| Мобильный АРМ 36 -50 | Dell xps 15          | Microsoft Windows 10 64-Bit      | Windows Defenders                 |
| Сервер 1-5           | x86-64               | Microsoft Windows Server 2019    | Windows Defenders                 |

- АСО:

1. коммутатор Siemens OSM (1 шт.);
2. коммутатор Siemens Scalance X202 21RT (2 шт.);



– каналы передачи данных. Сети связи расположены в пределах контролируемой зоны. Используются линии связи на основе кабелей типа «витая пара», волоконно-оптические и физические линии связи;

– ПО:

1. ОС MS Windows 10 64-Bit;
2. ОС MS Windows Server 2019;
3. ОС 3.1С Бухгалтерия;
4. ОС WeUp ERP For Healthcare (Программное обеспечение для поддержки ведения пациентов).

Состав ИС организации приведен на рисунке 2.1, разработанном по результатам составления исходных данных для проектирования.

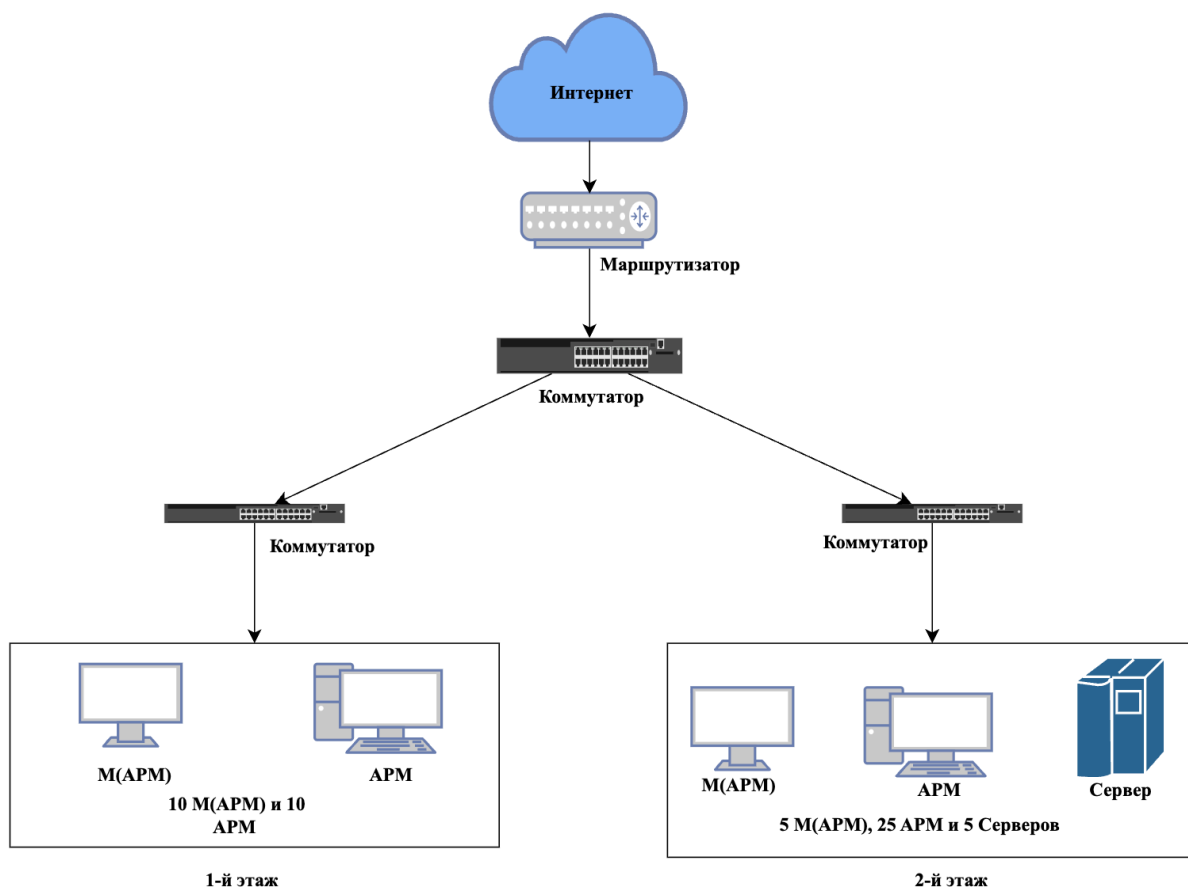


Рисунок 3 – Комплекс технических средств организации (вписать своё)

### 3.ПРЕДПРОЕКТНОЕ ИССЛЕДОВАНИЕ ОРГАНИЗАЦИИ (ДО ВНЕДРЕНИЯ МЕР)

#### 3.1.Модель нарушителя

Результат определения возможных способов реализации угроз безопасности на основе вида и категории нарушителя представлен в таблице 2.

Таблица 1 – Актуальные способы реализации УБИ

| Вид нарушителя                                                          | Категория нарушителя | Объект воздействия                                            | Доступные интерфейсы                                                                                        | Способы реализации                                                                                                                                                                                                                    |
|-------------------------------------------------------------------------|----------------------|---------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Авторизованные пользователи систем и сетей                              | Внутренний           | Облачные сервера, сетевое оборудование, АРМ (рабочие станции) | Интерфейсы для съемочных носителей, интерфейсы для пользователей, внутренние сетевые интерфейсы             | Ошибочные действия в ходе работы пользователя в системе. Поломка по неосторожности технического средства.<br>Уничтожение или кража технического средства<br>Предоставление несанкционированного доступа к конфиденциальной информации |
| Лица, обеспечивающие функционирование систем и сетей или обеспечивающие | Внутренний           | Сетевое оборудование, АРМ (рабочие станции)                   | Внутренние сетевые интерфейсы, интерфейсы для пользователей, интерфейсы для использования съемных носителей | Внедрение вредоносного ПО<br>Ошибочные действия при эксплуатации                                                                                                                                                                      |

|                                                                     |            |                                                                           |                                                                                                                         |                                                                                                                                                                                                                                                                        |
|---------------------------------------------------------------------|------------|---------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| системы оператора<br>(администрация,<br>охрана, уборщики<br>и т.д.) |            |                                                                           |                                                                                                                         |                                                                                                                                                                                                                                                                        |
| Системные<br>администраторы и<br>администраторы<br>безопасности     | Внутренний | Облачные<br>сервера,<br>сетевое<br>оборудование, АРМ<br>(рабочие станции) | Внутренние сетевые<br>интерфейсы, интерфейсы для<br>пользователей, интерфейсы<br>для использования съемных<br>носителей | Ошибочные действия в ходе работы<br>администратора в системе, предоставление<br>несанкционированного доступа к<br>конфиденциальной информации, внедрение<br>вредоносного программного обеспечения,<br>создание уязвимостей конфигурации<br>системы управления доступом |
| Конкурирующие<br>организации                                        | Внешний    | Облачные сервера                                                          | Внешние сетевые интерфейсы<br>коммутаторы,<br>маршрутизаторы                                                            | Внедрение вредоносного ПО<br>Использование уязвимостей конфигурации<br>системы управления доступом                                                                                                                                                                     |
| Бывшие работники<br>(пользователи)                                  | Внешний    | Облачные<br>сервера,<br>сетевое<br>оборудование, АРМ<br>(рабочие станции) | Внутренние сетевые<br>интерфейсы, интерфейсы для<br>пользователей, интерфейсы<br>для использования съемных<br>носителей | Использование уязвимостей конфигурации<br>системы управления доступом                                                                                                                                                                                                  |

|                                   |         |                                                               |                                                        |                                                                                                           |
|-----------------------------------|---------|---------------------------------------------------------------|--------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|
| Отдельные физические лица(хакеры) | Внешний | Облачные сервера, сетевое оборудование, АРМ (рабочие станции) | Внешние сетевые интерфейсы коммутаторы, маршрутизаторы | Внедрение вредоносного ПО<br>Использование уязвимостей конфигурации системы управления доступом<br>Фишинг |
|-----------------------------------|---------|---------------------------------------------------------------|--------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|

### 3.2. Модель угроз

УБИ характеризуется источниками угроз, уязвимостями (ошибками), которые могут быть использованы для реализации (способствовать возникновению) УБИ, способами (сценариями) реализации и возможными последствиями от реализации УБИ.

Перечень актуальных УБИ организации приведен в таблице 3.

Таблица 2 – Перечень актуальных УБИ организации

| Идентификатор УБИ | Наименование УБИ | Источник УБИ | Уязвимости (ошибки), которые могут быть использованы для реализации (способствовать возникновению) УБИ | Возможные способы (сценарии) реализации УБИ | Возможные последствия от реализации (возникновения) УБИ |
|-------------------|------------------|--------------|--------------------------------------------------------------------------------------------------------|---------------------------------------------|---------------------------------------------------------|
|-------------------|------------------|--------------|--------------------------------------------------------------------------------------------------------|---------------------------------------------|---------------------------------------------------------|

|         |                                                                                                                   |                                                                                           |                                                                                                                                                                                         |                                                                                                                                                                                      |                                                       |
|---------|-------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------|
| УБИ.003 | Угроза использования слабостей криптографических алгоритмов и уязвимостей в программном обеспечении их реализации | Внешний нарушитель со средним потенциалом<br>Внутренний нарушитель со средним потенциалом | Данная угроза обусловлена слабостями криптографических алгоритмов, а также ошибками в программном коде криптографических средств, их сопряжении с системой или параметрах их настройки. | Реализация угрозы возможна в случае наличия у нарушителя сведений об применяемых в системе средствах шифрования, реализованных в них алгоритмах шифрования и параметрах их настройки | Нарушение конфиденциальности<br>Нарушение целостности |
| УБИ.014 | Угроза длительного удержания вычислительных ресурсов пользователями                                               | Внешний нарушитель с низким потенциалом<br>Внутренний нарушитель с низким потенциалом     | Данная угроза обусловлена слабостями механизмов балансировки нагрузки и распределения вычислительных ресурсов.                                                                          | Реализация угрозы возможна в случае, если у нарушителя имеется возможность делать запросы, которые в совокупности требуют больше времени на выполнение, чем запросы пользователя     | Нарушение доступности                                 |

|         |                                                                             |                                                                                        |                                                                                                                                                                                                                                  |                                                                                                                                                                                                           |                              |
|---------|-----------------------------------------------------------------------------|----------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------|
| УБИ.019 | Угроза заражения DNS-кеша                                                   | Внешний нарушитель с низким потенциалом                                                | Данная угроза обусловлена слабостями механизмов проверки подлинности субъектов сетевого взаимодействия, а также уязвимостями DNS-сервера, позволяющими напрямую заменить DNS-кеш DNS-сервера.                                    | Реализация данной угрозы возможна в случае наличия у нарушителя привилегий, достаточных для отправки сетевых запросов к DNS-серверу                                                                       | Нарушение конфиденциальности |
| УБИ.027 | Угроза искажения вводимой и выводимой на периферийные устройства информации | Внешний нарушитель с высоким потенциалом<br>Внутренний нарушитель с низким потенциалом | Данная угроза обусловлена слабостями мер антивирусной защиты и контроля достоверности входных и выходных данных, а также ошибками, допущенными в ходе проведения специальных проверок аппаратных средств вычислительной техники. | Реализация данной угрозы возможна при условии наличия в дискредитируемой информационной системе вредоносного программного обеспечения (например, виртуальных драйверов устройств) или аппаратных закладок | Нарушение целостности        |

|         |                                                                      |                                                                                           |                                                                                       |                                                                                                                                                                                                               |                                                |
|---------|----------------------------------------------------------------------|-------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------|
| УБИ.031 | Угроза использования механизмов авторизации для повышения привилегий | Внешний нарушитель с низким потенциалом<br>Внутренний нарушитель с низким потенциалом     | Данная угроза обусловлена слабостями мер разграничения доступа к программам и файлам. | Реализация данной угрозы возможна в случае наличия у нарушителя каких-либо привилегий в системе                                                                                                               | Нарушение конфиденциальности                   |
| УБИ.033 | Угроза использования слабостей кодирования входных данных            | Внешний нарушитель со средним потенциалом<br>Внутренний нарушитель со средним потенциалом | Данная угроза обусловлена слабостями механизма контроля входных данных.               | Реализация данной угрозы возможна при условиях: дискредитируемая система принимает входные данные от нарушителя; нарушитель обладает возможностью управления одним или несколькими параметрами входных данных | Нарушение целостности<br>Нарушение доступности |

|         |                                                                         |                                                     |                                                                                                                                                                   |                                                                                                                                                                                                                                                                                                                                                            |                                                                 |
|---------|-------------------------------------------------------------------------|-----------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|
| УБИ.067 | Угроза<br>неправомерного<br>ознакомления с<br>защищаемой<br>информацией | Внутренний<br>нарушитель с<br>низким<br>потенциалом | Данная угроза обусловлена<br>уязвимостями средств контроля<br>доступа, ошибками в параметрах<br>конфигурации данных средств или<br>отсутствием указанных средств. | Реализация данной угрозы<br>не подразумевает установку<br>и использование<br>нарушителем специального<br>вредоносного программного<br>обеспечения. При этом<br>ознакомление может быть<br>проведено путём просмотра<br>информации с экранов<br>мониторов других<br>пользователей, с<br>отпечатанных документов,<br>путём подслушивания<br>разговоров и др. | Нарушение<br>конфиденциально<br>сти                             |
| УБИ.069 | Угроза<br>неправомерных<br>действий в каналах<br>связи                  | Внешний<br>нарушитель с<br>низким<br>потенциалом    | Данная угроза обусловлена<br>слабостями сетевых протоколов,<br>закрывающимися в отсутствии<br>проверки целостности и подлинности<br>получаемых данных.            | Реализация данной угрозы<br>возможна при условии<br>осуществления<br>нарушителем<br>несанкционированного<br>доступа к сетевому трафику                                                                                                                                                                                                                     | Нарушение<br>конфиденциально<br>сти<br>Нарушение<br>целостности |



|         |                                                                                                                                                                  |                                                                                           |                                                                                                                                                                                                                                                                                                |                                                                                                                                                                                    |                                                                                |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| УБИ.073 | Угроза несанкционированного доступа к активному и (или) пассивному виртуальному и (или) физическому сетевому оборудованию из физической и (или) виртуальной сети | Внешний нарушитель со средним потенциалом<br>Внутренний нарушитель со средним потенциалом | Данная угроза обусловлена ограниченностью функциональных возможностей (наличием слабостей) активного и (или) пассивного виртуального и (или) физического сетевого оборудования, входящего в состав виртуальной инфраструктуры, наличием у данного оборудования фиксированного сетевого адреса. | Реализация данной угрозы возможна при условии наличия уязвимостей в программном и (или) микропрограммном обеспечении сетевого оборудования                                         | Нарушение конфиденциальности<br>Нарушение целостности<br>Нарушение доступности |
| УБИ.104 | Угроза определения топологии вычислительной сети                                                                                                                 | Внешний нарушитель с низким потенциалом                                                   | Данная угроза связана со слабостями механизмов сетевого взаимодействия, предоставляющих клиентам сети открытую техническую информацию о сетевых узлах, а также с уязвимостями средств межсетевого экранирования (алгоритма работы и конфигурации правил фильтрации сетевого трафика).          | Реализация данной угрозы возможна в случае наличия у нарушителя возможности подключения к исследуемой вычислительной сети и наличием специализированного программного обеспечения, | Нарушение конфиденциальности                                                   |

|         |                                          |                                                     |                                                                                                                                                                                                                                          |                                                                                                                                                         |                                                                                             |
|---------|------------------------------------------|-----------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|
|         |                                          |                                                     |                                                                                                                                                                                                                                          | реализующего функцию<br>анализа сетевого трафика                                                                                                        |                                                                                             |
| УБИ.156 | Угроза утраты<br>носителей<br>информации | Внутренний<br>нарушитель с<br>низким<br>потенциалом | Данная угроза обусловлена<br>слабостями мер регистрации и учёта<br>носителей информации, а также мер<br>резервирования защищаемых данных                                                                                                 | Реализация данной угрозы<br>возможна вследствие<br>халатности сотрудников                                                                               | Нарушение<br>конфиденциально<br>сти<br>Нарушение<br>доступности                             |
| УБИ.006 | Угроза внедрения<br>кода или данных      | Внешний<br>нарушитель с<br>низким<br>потенциалом    | Данная угроза обусловлена:<br>наличием уязвимостей программного<br>обеспечения;<br>слабостями мер антивирусной защиты<br>и разграничения доступа;<br>наличием открытого Telnet-порта на<br>IoT-устройстве (только для<br>IoT-устройств). | Реализация данной угрозы<br>возможна:<br>в случае работы<br>дискредитируемого<br>пользователя с файлами,<br>поступающими из<br>недоверенных источников; | Нарушение<br>конфиденциально<br>сти<br>Нарушение<br>целостности<br>Нарушение<br>доступности |

|         |                                                                       |                                         |                                                                                                                                                                       |                                                                                                                                                                                                                                                                       |                                                                                |
|---------|-----------------------------------------------------------------------|-----------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
|         |                                                                       |                                         |                                                                                                                                                                       | при наличии у него привилегий установки программного обеспечения; в случае неизменных владельцем учетных данных IoT-устройства (заводских пароля и логина)                                                                                                            |                                                                                |
| УБИ.083 | Угроза несанкционированного доступа к системе по беспроводным каналам | Внешний нарушитель с низким потенциалом | Данная угроза обусловлена слабостями протоколов идентификации/аутентификации (таких как WEP, WPA и WPA2, AES), используемых для доступа к беспроводному оборудованию. | Реализация данной угрозы возможна при условии наличия у нарушителя специализированного программного обеспечения, реализующего функции эксплуатации уязвимостей протоколов идентификации/аутентификации беспроводных сетей, а также нахождения в точке приема сигналов | Нарушение конфиденциальности<br>Нарушение целостности<br>Нарушение доступности |

|         |                                         |                                                    |                                                                                                                                                        |                                                                                                                                                                                                                                                       |                                                                                             |
|---------|-----------------------------------------|----------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|
|         |                                         |                                                    |                                                                                                                                                        | дискредитируемой<br>беспроводной сети                                                                                                                                                                                                                 |                                                                                             |
| УБИ.139 | Угроза преодоления<br>физической защиты | Внешний<br>нарушитель со<br>средним<br>потенциалом | Данная угроза обусловлена<br>уязвимостями в системе контроля<br>физического доступа (отсутствием<br>замков в помещении, ошибками<br>персонала и т.п.). | Реализация данной угрозы<br>возможна при условии<br>успешного применения<br>нарушителем любого из<br>методов проникновения на<br>объект (обман персонала,<br>взлом замков и др.)                                                                      | Нарушение<br>конфиденциально<br>сти<br>Нарушение<br>целостности<br>Нарушение<br>доступности |
| УБИ.175 | Угроза «фишинга»                        | Внешний<br>нарушитель с<br>низким<br>потенциалом   | Данная угроза обусловлена<br>недостаточностью знаний<br>пользователей о методах и средствах<br>«фишинга».                                              | Реализация данной угрозы<br>возможна при условии<br>наличия у нарушителя:<br>сведений о конкретных<br>сайтах, посещаемых<br>пользователем, на которых<br>требуется ввод защищаемой<br>информации;<br>средств создания и запуска<br>поддельного сайта; | Нарушение<br>конфиденциально<br>сти                                                         |

|         |                                                         |                                                    |                                                                                                                                                                                                                                                                       |                                                                                                                               |                                                      |
|---------|---------------------------------------------------------|----------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------|
|         |                                                         |                                                    |                                                                                                                                                                                                                                                                       | сведений о контактах<br>пользователя с доверенной<br>организацией (номер<br>телефона, адрес<br>электронной почты и др.).      |                                                      |
| УБИ.189 | Угроза<br>маскирования<br>действий<br>вредоносного кода | Внешний<br>нарушитель со<br>средним<br>потенциалом | Данная угроза обусловлена наличием<br>способов маскирования программного<br>кода, не учтенных сигнатурными<br>базами средств защиты информации,<br>а также механизмов операционной<br>системы, позволяющих осуществить<br>поиск модулей средств защиты<br>информации. | Реализация данной угрозы<br>возможна при условии<br>использования в системе<br>устаревших версий средств<br>защиты информации | Нарушение<br>целостности<br>Нарушение<br>доступности |

### 3.3.Предварительная оценка рисков

Анализ и оценка рисков организации осуществлялась в количественном виде на основе ГОСТ Р ИСО/МЭК 27005-2010. Было выделено 16 наиболее актуальных угроз, для которых была проведена углубленная оценка рисков на основе формулы 1.

$$\text{Риск} = \text{Вероятность (\%)} * \text{Ущерб} \quad (1)$$

Вероятность реализации УБИ была рассчитана на основе экспертной оценки с помощью формулы 2 (выбрать метод экспертной оценки, привести табличку с мнениями 5 экспертов, с помощью коэффициента вариации или конкордации оценить согласованность).

$$\text{Вероятность (\%)} = \text{Сумма вероятностей} / \text{Количество экспертов} \quad (2)$$

Согласованность экспертов оценена на основе значений коэффициента вариации, вычисляемого по формуле 3:

$$CV = \sigma / X * 100\% \quad (3),$$

где

$\sigma$  - стандартное отклонение,

X - среднее значение.

Расчеты вероятности реализации угроз представлена в таблице 4.

Таблица 3 – Оценка экспертов

|         | Идентификатор УБИ |      |      |      |      |      |      |      |      |      |     |      |      |      |      |      |
|---------|-------------------|------|------|------|------|------|------|------|------|------|-----|------|------|------|------|------|
| Эксперт | 003               | 014  | 019  | 027  | 031  | 033  | 067  | 069  | 073  | 104  | 156 | 006  | 083  | 139  | 175  | 189  |
| 1       | 11                | 16   | 14   | 15   | 9    | 25   | 12   | 26   | 17   | 14   | 19  | 18   | 33   | 21   | 25   | 30   |
| 2       | 13                | 7    | 10   | 14   | 16   | 18   | 19   | 16   | 20   | 15   | 17  | 19   | 28   | 26   | 20   | 34   |
| 3       | 8                 | 13   | 16   | 17   | 7    | 15   | 19   | 16   | 18   | 20   | 10  | 21   | 34   | 19   | 22   | 30   |
| 4       | 12                | 10   | 10   | 18   | 7    | 21   | 13   | 18   | 20   | 20   | 14  | 22   | 27   | 25   | 23   | 32   |
| 5       | 10                | 11   | 16   | 14   | 8    | 21   | 19   | 24   | 13   | 16   | 10  | 19   | 27   | 23   | 23   | 30   |
| Среднее | 10,8              | 11,4 | 13,2 | 15,6 | 9,4  | 20   | 16,4 | 20   | 17,6 | 17   | 14  | 19,8 | 29,8 | 22,8 | 22,6 | 31,2 |
| CV      | 17,8              | 29,5 | 23   | 11,6 | 40,2 | 18,7 | 21,8 | 23,5 | 16,4 | 16,6 | 29  | 8,3  | 11,5 | 12,6 | 8    | 5,7  |

Оценка ущерба от реализации УБИ производилась на основе данных, представленных бухгалтерией организации, и включает в себя активы, штрафы, амортизацию, затраты на восстановлении (таблица 5).

Таблица 4 – Оценка ущерба от реализации

| Идентификатор<br>УБИ | Наименование УБИ                                                                                                                       | Источник УБИ                                                                                    | Вероятность<br>реализации УБИ<br>(%) | Ущерб от реализации УБИ<br>(руб.) | Риск (руб.) |
|----------------------|----------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|--------------------------------------|-----------------------------------|-------------|
| УБИ.003              | Угроза использования<br>слабостей<br>криптографических<br>алгоритмов и<br>уязвимостей в<br>программном<br>обеспечении их<br>реализации | Внешний нарушитель со<br>средним потенциалом<br>Внутренний нарушитель со<br>средним потенциалом | 10,8                                 | 1 000 000                         | 108 000     |
| УБИ.014              | Угроза длительного<br>удержания<br>вычислительных<br>ресурсов пользователями                                                           | Внешний нарушитель с низким<br>потенциалом<br>Внутренний нарушитель с<br>низким потенциалом     | 11,4                                 | 550 000                           | 62 700      |

|         |                                                                                      |                                                                                                 |      |           |         |
|---------|--------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|------|-----------|---------|
| УБИ.019 | Угроза заражения<br>DNS-кеша                                                         | Внешний нарушитель с низким<br>потенциалом                                                      | 13,2 | 450 000   | 59 400  |
| УБИ.027 | Угроза искажения<br>вводимой и выводимой на<br>периферийные<br>устройства информации | Внешний нарушитель с<br>высоким потенциалом<br>Внутренний нарушитель с<br>низким потенциалом    | 15,6 | 500 000   | 78 000  |
| УБИ.031 | Угроза использования<br>механизмов авторизации<br>для повышения<br>привилегий        | Внешний нарушитель с низким<br>потенциалом<br>Внутренний нарушитель с<br>низким потенциалом     | 9,4  | 1 100 000 | 103 400 |
| УБИ.033 | Угроза использования<br>слабостей кодирования<br>входных данных                      | Внешний нарушитель со<br>средним потенциалом<br>Внутренний нарушитель со<br>средним потенциалом | 20   | 1 000 000 | 200 000 |
| УБИ.067 | Угроза неправомерного<br>ознакомления с<br>защищаемой<br>информацией                 | Внутренний нарушитель с<br>низким потенциалом                                                   | 16,4 | 1 100 000 | 180 400 |



|         |                                                                                                                                                                  |                                                                                           |      |           |         |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|------|-----------|---------|
| УБИ.069 | Угроза неправомерных действий в каналах связи                                                                                                                    | Внешний нарушитель с низким потенциалом                                                   | 20   | 1 100 000 | 220 000 |
| УБИ.073 | Угроза несанкционированного доступа к активному и (или) пассивному виртуальному и (или) физическому сетевому оборудованию из физической и (или) виртуальной сети | Внешний нарушитель со средним потенциалом<br>Внутренний нарушитель со средним потенциалом | 17,6 | 1 000 000 | 176 000 |
| УБИ.104 | Угроза определения топологии вычислительной сети                                                                                                                 | Внешний нарушитель с низким потенциалом                                                   | 17   | 2 200 000 | 374 000 |
| УБИ.156 | Угроза утраты носителей информации                                                                                                                               | Внутренний нарушитель с низким потенциалом                                                | 14   | 1 200 000 | 168 000 |
| УБИ.006 | Угроза внедрения кода или данных                                                                                                                                 | Внешний нарушитель с низким потенциалом                                                   | 19,8 | 1 650 000 | 326 700 |

|            |                                                                       |                                           |      |           |           |
|------------|-----------------------------------------------------------------------|-------------------------------------------|------|-----------|-----------|
| УБИ.083    | Угроза несанкционированного доступа к системе по беспроводным каналам | Внешний нарушитель с низким потенциалом   | 29,8 | 1 000 000 | 298 000   |
| УБИ.139    | Угроза преодоления физической защиты                                  | Внешний нарушитель со средним потенциалом | 22,8 | 1 100 000 | 250 800   |
| УБИ.175    | Угроза «фишинга»                                                      | Внешний нарушитель с низким потенциалом   | 22,6 | 1 000 000 | 226 000   |
| УБИ.189    | Угроза маскирования действий вредоносного кода                        | Внешний нарушитель со средним потенциалом | 31,2 | 1 650 000 | 514 800   |
| Итого риск |                                                                       |                                           |      |           | 3 346 200 |

На основе представленной таблицы было принято решение о следующей обработке рисков:

Таблица 5 – Обработка рисков

| Идентификатор УБИ | Наименование УБИ                                                                                                  | Решение        |
|-------------------|-------------------------------------------------------------------------------------------------------------------|----------------|
| УБИ.003           | Угроза использования слабостей криптографических алгоритмов и уязвимостей в программном обеспечении их реализации | Снижение риска |
| УБИ.014           | Угроза длительного удержания вычислительных ресурсов пользователями                                               | Снижение риска |
| УБИ.019           | Угроза заражения DNS-кеша                                                                                         | Снижение риска |

|         |                                                                                                                                                                  |                |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------|
| УБИ.027 | Угроза искажения вводимой и выводимой на периферийные устройства информации                                                                                      | Снижение риска |
| УБИ.031 | Угроза использования механизмов авторизации для повышения привилегий                                                                                             | Снижение риска |
| УБИ.033 | Угроза использования слабостей кодирования входных данных                                                                                                        | Снижение риска |
| УБИ.067 | Угроза неправомерного ознакомления с защищаемой информацией                                                                                                      | Снижение риска |
| УБИ.069 | Угроза неправомерных действий в каналах связи                                                                                                                    | Снижение риска |
| УБИ.073 | Угроза несанкционированного доступа к активному и (или) пассивному виртуальному и (или) физическому сетевому оборудованию из физической и (или) виртуальной сети | Снижение риска |
| УБИ.104 | Угроза определения топологии вычислительной сети                                                                                                                 | Снижение риска |
| УБИ.156 | Угроза утраты носителей информации                                                                                                                               | Снижение риска |
| УБИ.006 | Угроза внедрения кода или данных                                                                                                                                 | Снижение риска |
| УБИ.083 | Угроза несанкционированного доступа к системе по беспроводным каналам                                                                                            | Снижение риска |
| УБИ.139 | Угроза преодоления физической защиты                                                                                                                             | Снижение риска |
| УБИ.175 | Угроза «фишинга»                                                                                                                                                 | Снижение риска |
| УБИ.189 | Угроза маскирования действий вредоносного кода                                                                                                                   | Снижение риска |

#### **4.ТРЕБОВАНИЯ ПО ЗАЩИТЕ ИНФОРМАЦИИ В ОРГАНИЗАЦИИ**

##### **4.1.Требования по защите информации сформулированы на основе следующих документов**

1. ГОСТ Р ИСО/МЭК 27004-2021 “Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования”;
2. ГОСТ Р 51583-2014 «Порядок создания автоматизированных систем в защищенном исполнении»;
3. Федеральный закон от 27 июля 2006 г. N 149-ФЗ “Об информации, информационных технологиях и о защите информации”;
4. Приказ от 11 февраля 2013 г. N 17 об утверждении требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах;
5. Федеральный закон от 29.07.2004 N 98-ФЗ (ред. от 09.03.2021) "О коммерческой тайне";
6. Федеральный закон от 21.12.1994 N 69-ФЗ (ред. от 11.06.2021) "О пожарной безопасности" (с изм. и доп., вступ. в силу с 09.12.2021);
7. Федеральный закон от 30.04.2021 N 117-ФЗ (ред. от 11.06.2021) “Технический регламент о требованиях пожарной безопасности”;
8. Приказ ФАПСИ от 13 июля 2020 г. N 658/20 "Об обращении со средствами криптографической защиты информации";
9. Руководящий документ. Решение председателя Гостехкомиссии России от 30 марта 1992 г. «Средства вычислительной техники. Защита от несанкционированного доступа к информации. Показатели защищенности от несанкционированного доступа к информации»;
10. Руководящий документ. Решение председателя Гостехкомиссии России от 30 марта 1992 г. «Автоматизированные системы. Защита от несанкционированного доступа к информации. Классификация автоматизированных систем и требования по защите информации»;
11. Руководящий документ. Средства вычислительной техники. Межсетевые экраны. Защита от несанкционированного доступа к информации. Показатели защищенности от несанкционированного доступа к информации. Утверждено решением председателя Государственной

технической комиссии при Президенте Российской Федерации от 25 июля 1997 г.

#### **4.2. Учетные при разработке требования руководящих документов**

1. “Разработать план обработки рисков, определяющий соответствующие действия руководства, ресурсы, обязанности и приоритеты в отношении менеджмента рисков ИБ” [1];
2. “Реализовать план обработки рисков для достижения намеченных целей управления, включающий в себя вопросы финансирования, а также распределение функций и обязанностей” [1];
3. “Определить способ измерения результативности выбранных мер управления или их групп и использования этих измерений для оценки результативности управления с целью получить сравнимые и воспроизводимые данные” [1];
4. “Силовые и телекоммуникационные кабельные сети, по которым передаются данные или поддерживаются информационные услуги, необходимо защищать от перехвата информации или повреждения” [1];
5. “Должны быть реализованы меры по обнаружению, предотвращению проникновения и восстановлению после проникновения вредоносного кода, а также должны быть установлены процедуры обеспечения соответствующего оповещения пользователей” [1];
6. “Разработку организационно-распорядительных документов, определяющих мероприятия по ЗИ в ходе эксплуатации АСЗИ” [2];
7. Статья 16. Защита информации [3];
8. Статья 17. Ответственность за правонарушения в сфере информации, информационных технологий и защиты информации [3];
9. “Ограничение доступа к информации, составляющей коммерческую тайну, путем установления порядка обращения с этой информацией и контроля за соблюдением такого порядка” [5];
10. “Исключается доступ к информации, составляющей коммерческую тайну, любых лиц без согласия ее обладателя” [5];
11. Статья 37. Права и обязанности организаций в области пожарной безопасности [6];

12. Статья 103. Требования к автоматическим установкам пожарной сигнализации [7];
13. “Состав и содержание организационных и технических мер, необходимых для выполнения установленных Правительством Российской Федерации требований к защите персональных данных для 3 уровня защищенности” [8].

## **5.ТЕХНИЧЕСКОЕ ЗАДАНИЕ НА РАЗРАБОТКУ КСЗИ (часть)**

Требования к системе защиты информации:

### **5.1.Общие сведения**

Настоящее техническое задание (ТЗ) разработано для информационной системы персональных данных **ООО «MedCare»** (ИСПДн) и описывает требования, предъявляемые к построению системы защиты, внедрению системы защиты и

передаче прав на использование программного обеспечения с целью создания системы защиты информации в ИСПДн.

Полное наименование и обозначение системы: «Система защиты информации, обрабатываемой в информационной системе персональных данных **ООО «MedCare»**».

Сокращенное наименование системы: СЗПДн.

Работы по поставке и пуско-наладке оборудования СЗПДн проводятся на основании данного ТЗ.

Финансирование работ осуществляется из средств бюджета **ООО «MedCare»**.

По завершении этапов работ Исполнитель выдаст Аттестат соответствия требованиям по безопасности информации ИСПДн.

Порядок оформления и предъявления Заказчику результатов работ определяется на основании действующих стандартов и договорных документов между Заказчиком и Исполнителем.

### **5.2.Цели создания СЗПДн**

Целями создания СЗПДн являются:

- обеспечение защищенности ИСПДн в процессе обработки и хранения ПДн, обеспечение конфиденциальности ПДн при их обработке, а также других необходимых характеристик защищенности информации (целостности, доступности);
- соответствие требованиям обеспечения ИБ при обработке ПДн в ИСПДн, регламентируемых РД ФСТЭК России и ФСБ России.

### 5.3. Характеристика объекта защиты

Объекты защиты больниц в рамках информационных систем персональных данных (ИСПДн) включают в себя следующие элементы:

- база данных клиентов: это база данных, содержащая личные данные клиентов, такие как имя, адрес, паспортные данные, медицинская информация клиента,...;
- больничная система: это информационная система, используемая для обработки и хранения данных, связанных с планами лечения каждого клиента, информацией об источниках лекарств и медицинского оборудования, а также информацией о фонде планирования больницы и т. д.;
- серверы функционируют под управлением Microsoft Windows Server 2019;
- сетевое оборудование: построено на основе коммуникационного оборудования:
  - коммутатор Eltex MES2124MB (1 шт.);
  - коммутатор Siemens OSM (1 шт.);
  - коммутатор Siemens Scalance X202 21RT (4 шт.).
- сети связи расположены в пределах контролируемой зоны;
- обработка ПДн в ИСПДн осуществляется с использованием средств автоматизации;
- программное обеспечение: ПО больниц, ОС WeUp ERP For Healthcare (Программное обеспечение для поддержки ведения пациентов), ОС MS Windows 10 64-Bit, ОС 3.1С Бухгалтерия;
- физическая инфраструктура: (40 автоматизированных рабочих мест (АРМ), 5 серверов и 15 мобильных АРМ).

### 5.4. Расположение объекта информатизации

ИСПДн располагается в офисе **ООО «MedCare»**.



Офис ООО «MedCare» располагается в здании по адресу: г. Санкт – Петербург, пер. Вяземский, д. 5-7.

## **5.5.Техническое решение по созданию СЗПДн**

Архитектура СЗПДн должна обеспечивать реализацию функций безопасности на всех технологических этапах эксплуатации ИСПДн, в том числе при проведении технического обслуживания и ремонта.

В СЗПДн должны использоваться только средства защиты информации, сертифицированные в установленном порядке на соответствие функциональным требованиям информационной безопасности в системе сертификации ФСТЭК России и ФСБ России.

### **5.5.1.Этап создания СЗПДн**

Работы включают в себя следующие этапы:

- этап 1: Предпроектное обследование;
- этап 2: Разработка и согласование Технического Задания на создание СЗПДн;
- этап 3: Разработка организационно-распорядительной документации;
- этап 4: Тех-рабочее проектирование.

Каждый этап выполняется Исполнителем в соответствии с договором, заключенным с Заказчиком.

Перед выполнением каждого этапа Исполнитель заключает с Заказчиком отдельный договор.

### **5.5.2.Требования к режимам функционирования системы**

При проектировании СЗПДн, установке СЗПДн и выполнении пусконаладочных работ СЗИ должны быть реализованы следующие режимы функционирования:

- режим установки и конфигурирования;
- режим отладки;

- рабочий режим.

Режим конфигурирования используется для начальной настройки системы защиты информации (СЗИ) и выполняется на этапе пусконаладочных работ. В этом режиме осуществляется настройка СЗИ путем создания, редактирования и применения политик, шаблонов и настроек, необходимых для определенных типов доступа.

Режим установки и конфигурирования предполагает установку и начальную настройку программного обеспечения. Режим отладки предназначен для отладки системы защиты информации (СЗИ) и выполняется после завершения режима конфигурирования. В этом режиме ведется журнал работы компонентов СЗИ, а также происходит настройка методов и реакции компонентов на воздействия.

### **5.5.3. Требования к надежности**

Аппаратно-программные компоненты СЗПДн должны быть надежными, доступными и способными обеспечивать непрерывное функционирование СЗПДн и позволять осуществлять процедур резервирования и восстановления для обеспечения непрерывности работы системы в случае возникновения сбоев.

### **5.5.4. Требования безопасности**

СЗПДн должна обеспечивать конфиденциальность данных, контроль доступа, защиту от угроз и атак, шифрование, физическую безопасность, соблюдение стандартов, обучение персонала, аудиты и реакцию на инциденты.

Комплекс технических решений по созданию СЗПДн, выбранный по результатам этапа, должен представлять собой набор программно-аппаратных средств защиты информации, позволяющий выполнить следующие требования к СЗПДн:

- в составе СЗПДн должны использоваться средства защиты информации, прошедшие в установленном порядке процедуру оценки соответствия (сертификацию) требованиям законодательства Российской Федерации в области обеспечения безопасности информации, обеспечивающие установленный в ИСПДн уровень защищенности персональных данных и обеспечивающие выполнение, в том числе, следующих функций:
  - защиту от несанкционированного доступа к ресурсам ИСПДн, включая идентификацию, аутентификацию, управление доступом;

- обеспечение антивирусной защиты;
  - обеспечение межсетевого экранирования и защиты от сетевых атак;
  - обнаружение вторжений;
  - криптографическую защиту информации, в том числе информации передаваемой между площадками ИСПДн и информации передаваемой между ИСПД и пользователями ИСПДн по протоколу HTTPS;
  - анализ защищенности и выявление уязвимостей ИСПДн и СЗПДн.
- СЗПДн должна обеспечивать масштабируемость, т. е. при развитии информационной инфраструктуры ИСПДн и при развитии СЗПДн должна также допускаться возможность развития СЗПДн с сохранением требуемого уровня обеспечения безопасности информации.

#### **5.5.5. Требования к квалификации исполнителя**

Исполнитель должен иметь в штате больницы не менее 3 (трех) специалистов, имеющих базовое образование и специализацию в области защиты информации.

Исполнитель должен иметь опыт работы с информационными системами персональных данных в сфере здравоохранения не менее 3 лет.

Исполнитель должен иметь Аттестаты аккредитации:

- органа по аттестации ФСТЭК России;
- испытательной лаборатории ФСТЭК России.

Исполнитель должен обладать практическим опытом работы по следующим направлениям:

- понимание специфических для больницы процессов и требований, таких как управление информацией о пациентах, планы лечения и т. д.
- внедрение и сопровождение средств защиты информации в ИСПДн;
- разработка, внедрение и сопровождение программных средств защиты информации;
- проведение сертификационных испытаний программных и программно-технических средств защиты информации;
- оказание услуг по внедрению (применению) криптографических средств защиты информации, электронной цифровой подписи;
- оказание услуг удостоверяющего центра.

При выполнении работ Исполнитель должен руководствоваться следующей нормативной базой:

- федеральный Закон от 27.07.2006 г. № 152-ФЗ «О персональных данных»;
- постановление правительства РФ от 1.11.2012 г. № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных»;
- приказ ФСТЭК России от 18.02.2013 № 21 «Об утверждении Состав и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных»;
- приказ ФСБ России от 10.07.2014 № 378 «Об утверждении Состав и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных с использованием средств криптографической защиты информации, необходимых для выполнения установленных Правительством Российской Федерации требований к защите персональных данных для каждого из уровней защищенности»;
- постановление Правительства Российской Федерации от 15.09.2008 г. №687 «Об утверждении Положения об особенностях обработки персональных данных, осуществляемой без использования средств автоматизации»;
- ГОСТ РО 0043-003-2012 «Защита информации. Аттестация объектов информатизации. Общие положения».

## 6. ПРЕДЛАГАЕМЫЕ МЕРЫ И СРЕДСТВА ПО ЗАЩИТЕ ИНФОРМАЦИИ В ОРГАНИЗАЦИИ

### 6.1. Организационно-правовая защита информации

К организационно-правовой защите информации в организации ООО «MedCare» относятся:

1. Политика Информационной безопасности (разработка и внедрение политик и процедур по обработке, хранению и передаче медицинской информации, включая правила доступа к данным, уровни доступа и процедуры уничтожения информации по истечении срока хранения);
2. Регламент управления уязвимостями информационной безопасности;
3. Обеспечение проведения мероприятий по проверке систем защиты (внешний аудит безопасности).

Представленные меры способствуют снижению вероятности реализации и риска ИБ следующих УБИ:

- определение состава организационных мер ЗИ, ТС и ПС системы ЗИ, выбор сертифицированных СЗИ с учетом их совместимости с основными ТС и ПС создаваемой (модернизируемой) АСЗИ;
- внедрение системы ЗИ, включая разработку организационно-распорядительных документов, определяющих мероприятия по ЗИ в ходе эксплуатации АСЗИ;

и способствуют снижению вероятности реализации и риска ИБ следующих УБИ:

- угроза доступа к защищаемым файлам с использованием обходного пути;
- угроза внедрения кода или данных;
- угроза несанкционированного копирования защищаемой информации.

Таблица 6 – Организационно-правовая ЗИ

| Наименование                         | Стоимость, руб. |
|--------------------------------------|-----------------|
| Политика ИБ                          | 55 000          |
| Регламент управления уязвимостями ИБ | 35 000          |
| Внешний аудит безопасности           | 80 000          |

На организационно-правовые меры по защите информации необходимо: 170 000 руб.

## 6.2. Программно-аппаратная защита информации

В качестве потенциальных программно-аппаратных средств защиты информации были рассмотрены решения, представленные в таблице 7.

Таблица 7 – Средства антивирусной защиты

| Наименование средства                   | Достоинства                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | Недостатки | Финальная стоимость (руб.)                |
|-----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|-------------------------------------------|
| Kaspersky Endpoint Security для бизнеса | <ol style="list-style-type: none"><li>1. Защита Windows, Linux, Mac, Android и iOS</li><li>2. Безопасность мобильных устройств</li><li>3. Контроль программ, веб-контроль и контроль устройств на рабочих станциях</li><li>4. Поведенческий анализ, Откат вредоносных действий</li><li>5. Анализ уязвимостей и защита от эксплойтов</li><li>6. Разрешения на переключение среды и система предотвращения вторжений</li><li>7. Интеграция с AMSI, Microsoft AD, Syslog, RMM, PSA, EMM</li><li>8. Интеграция Kaspersky Sandbox</li></ol> | 1 год      | ~114 361<br>(зависит от количества узлов) |
| ESET NOD32 Antivirus                    | Включает возможности автоматического сканирования компьютера во время его простоя, проверки файлов непосредственно во время загрузки и                                                                                                                                                                                                                                                                                                                                                                                                 | 1 год      | ~113 433<br>(зависит от количества узлов) |

|                                               |                                                                                                                                                                                                                                                                                                                                                                                                                                       |       |                                           |
|-----------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------------------------------------------|
|                                               | возможность отменять установленные обновления                                                                                                                                                                                                                                                                                                                                                                                         |       |                                           |
| Антивирус Dr. Web Комплект для малого бизнеса | Новый компонент Превентивная защита блокирует любые автоматические модификации критических объектов системы, позволяя пользователям контролировать доступ к тем или иным объектам Windows, различным приложениям и сервисам, обеспечивая проактивную защиту от вредоносных программ.                                                                                                                                                  | 1 год | ~116 871<br>(зависит от количества узлов) |
| Avast Pro Antivirus                           | <ol style="list-style-type: none"> <li>1. Защита в режиме реального времени от вирусов, программ-шпионов, троянов, руткитов и других угроз;</li> <li>2. Быстрая работа и эффективная производительность ПК;</li> <li>3. Быстрое реагирование на новые и возникающие угрозы;</li> <li>4. Мгновенная антивирусная проверка файлов, приложений и веб-сайтов;</li> <li>5. Откат изменений, сделанных вредоносными программами.</li> </ol> | 1 год | ~109 997<br>(зависит от количества узлов) |

На основании анализа, проведенного в таблице 7, в качестве средства антивирусной защиты выбрано Kaspersky Endpoint Security для бизнеса.

Представленные меры соответствуют следующим требованиям по защите информации:

- должны обеспечивать установку и (или) запуск только разрешенного к использованию в информационной системе программного обеспечения или исключать возможность установки и (или) запуска запрещенного к использованию в информационной системе программного обеспечения;
- должны обеспечивать сбор, запись, хранение и защиту информации о событиях безопасности в информационной системе, а также возможность просмотра и анализа информации о таких событиях и реагирование на них;
- должны обеспечивать обнаружение действий в информационной системе, направленных на несанкционированный доступ к информации, специальные воздействия на информационную систему и (или) персональные данные в целях добывания, уничтожения, искажения и блокирования доступа к персональным данным, а также реагирование на эти действия.

и способствуют снижению вероятности реализации и риска ИБ следующих УБИ:

- УБИ.019. Угроза заражения DNS-кеша;
- УБИ.069. Угроза неправомерных действий в каналах связи;
- УБИ.104. Угроза определения топологии вычислительной сети;
- УБИ.006. Угроза внедрения кода или данных;
- УБИ.175. Угроза «фишинга»;
- УБИ.189. Угроза маскирования действий вредоносного кода;

На представленные меры по защите информации необходимо выделить: 114 361 руб.

### **6.3.Инженерно-техническая защита информации**

В качестве потенциальных программно-аппаратных средств защиты информации были рассмотрены решения, представленные в таблице 8.

Таблица 8 – Средства защиты информации



| Наименование средства                                                     | Достоинства                                                                                                                                                                                         | Недостатки                                                                                                                              | Финальная стоимость (руб.)  |
|---------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Система постановки виброакустических и акустических помех ЛГШ-404 (2 шт.) | Сертифицирован<br>фстэк россии по 2 классу защиты<br>Возможность установки в вп до 2 категории включительно<br>Возможность подключения до 40 преобразователей<br>Возможность изменения комплектации | 1. Неблагоприятное воздействие на здоровье человека<br>2. Расходы на периодический осмотр и техническое обслуживание<br>3. Высокая цена | 76 600<br>(38 300 руб./шт.) |
| Система постановки виброакустических и акустических помех ЛГШ-402 (2 шт.) | Сертифицирован<br>фстэк россии по 4 классу защиты<br>Возможность подключения до 8 преобразователей                                                                                                  | Расходы на периодический осмотр и техническое обслуживание                                                                              | 66 200<br>(33 100 руб./шт.) |

На основании анализа, проведенного в таблице 8, в качестве средства системы контроля доступа выбрано «Система постановки виброакустических и акустических помех ЛГШ-402 (2 шт.)».

Представленные меры соответствуют следующим требованиям по защите информации:

- «Силовые и телекоммуникационные кабельные сети, по которым передаются данные или поддерживаются информационные услуги, необходимо защищать от перехвата информации или повреждения» (ГОСТ Р ИСО МЭК 27001–2021).

На представленные меры по защите информации необходимо выделить: 66 200 руб.

#### 6.4. Технические средства охраны

Для организации ООО “MedCare” предлагаются следующие варианты обеспечения видеонаблюдения, СКУД и охрано-пожарной сигнализации.

Расчеты соответствуют следующим требованиям:

1. должны обеспечивать присвоение субъектам и объектам доступа уникального признака (идентификатора), сравнение предъявляемого субъектом (объектом) доступа идентификатора с перечнем присвоенных идентификаторов, а также проверку принадлежности субъекту (объекту) доступа предъявленного им идентификатора (подтверждение подлинности);

2. должны обеспечивать управление правами и привилегиями субъектов доступа, разграничение доступа субъектов доступа к объектам доступа на основе совокупности установленных в информационной системе правил разграничения доступа, а также обеспечивать контроль за соблюдением этих правил;

3. должны обеспечивать авторизованный доступ пользователей, имеющих права по доступу, к персональным данным, содержащимся в информационной системе, в штатном режиме функционирования информационной системы.

и способствуют снижению вероятности реализации и риска ИБ следующих УБИ:

1. незаконное проникновение в помещения с повышенными требованиями;
2. нарушение действующего в медицинских учреждениях режима;
3. потеря лекарств, личных вещей и пациентов;
4. разглашение медицинской информации;
5. противоправные действия на территории учреждения.

Таблица 9 – Средства видеонаблюдения

| Наименование средства     | Достоинства                                                                                                                                                           | Недостатки                     | Финальная стоимость (руб.)  |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------|-----------------------------|
| Reolink RLC-410W (22 шт.) | 1. Объектив 1/2.7" 4 Мегапикселя CMOS<br>2. Разрешение 2560 x 1440 (4.0 MP)<br>3. Фокусное расстояние F=2.0, f=4.0мм<br>4. Питание PoE, 12В, блок питания в комплекте | Ограниченный угол обзора (80°) | 192 500<br>(8 750 руб./шт.) |

|                                      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |                                         |                                        |
|--------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------|----------------------------------------|
|                                      | <p>5. Встроенный микрофон</p> <p>6. Встроенный слот для MicroSD до 128Гб</p> <p>7. Частоты WiFi 2.4/5G</p> <p>8. Рабочая температура: -30 +60 °C</p> <p>9. ИК подсветка 30 метров</p>                                                                                                                                                                                                                                                                                                                                                          |                                         |                                        |
| <p>GF-NV1601HD v2</p> <p>(2 шт.)</p> | <p>Сетевой видеорегистратор GF-NV1601HD v2 предназначен для записи на жесткий диск видео и аудио информации, поступающей от сетевых камер видеонаблюдения. Количество каналов (при разрешении 1080p): 16. Видеорегистратор поддерживает следующие режимы работы: Макс. 16*8M GF-NV1601HD v2 имеет Аудио входы/выходы - 0 / 1 и входы/выходы Тревога – 0 / 0. Для записи могут быть использованы жесткие диски: 1 x 14 Тб. Видеорегистратор обеспечивает удаленный доступ с компьютера или мобильных устройств как по локальной сети, так и</p> | <p>Зависимость от облачного сервиса</p> | <p>25 600</p> <p>(12 800 руб./шт.)</p> |

|                                 |                                                                                                                                                                                                                                                                                                      |                                                 |                            |
|---------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------|----------------------------|
|                                 | из любой точки при наличии интернет-соединения.                                                                                                                                                                                                                                                      |                                                 |                            |
| Seagate Surveillance<br>(2 шт.) | <p>Специфика эксплуатации жесткого диска Seagate Surveillance ST1000VX001 1 Тб заключается в возможности одновременной записи высококачественного видео с высоким разрешением с нескольких камер видеонаблюдения. Характеризующийся объемом 1 терабайт, жесткий диск выполнен с одной пластиной.</p> | до 8 приводов в одну систему, а также 64 камеры | 13 120<br>(6 560 руб./шт.) |

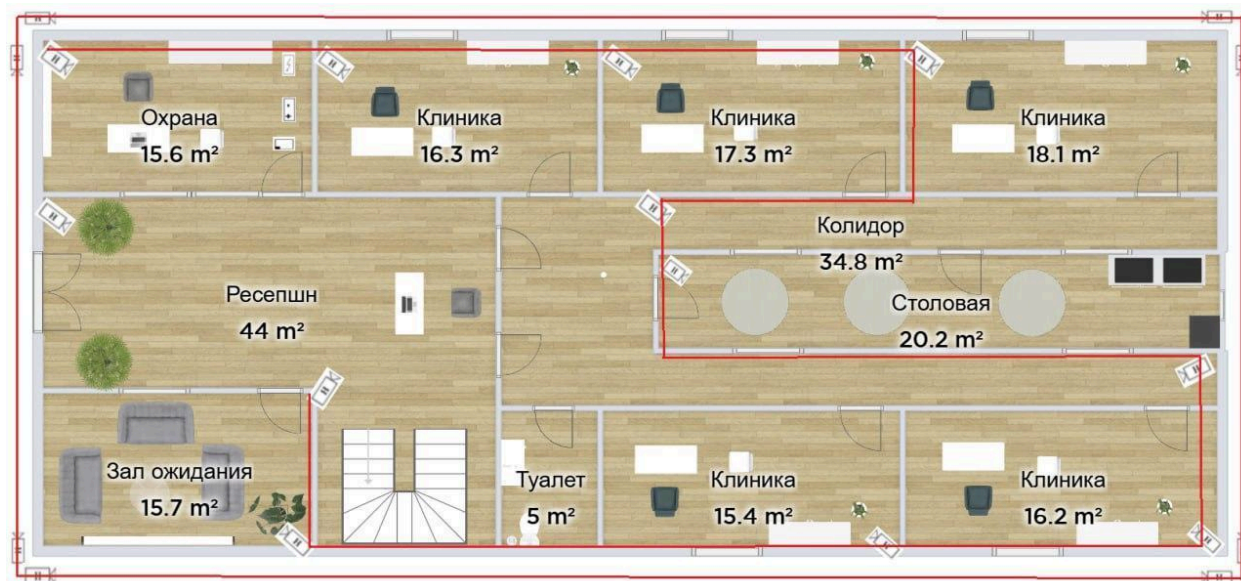


Рисунок 1 – План помещения с системой видеонаблюдения на первом этаже



Рисунок 2 – План помещения с системой видеонаблюдения на втором этаже

Условные обозначения:

-  блочный щит управления;
-  камера наблюдения;
-  источники электропитания;
-  кондуктометрическая поверочная установка стационарная.

Таблица 10 – Средства системы контроля доступа

| Наименование средства                                       | Достоинства                                                                                                                | Недостатки                                                    | Финальная стоимость (руб.) |
|-------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------|----------------------------|
| Замок<br>(24 шт.)                                           | Сила удержания 60 кг                                                                                                       | Не выявлено                                                   | 64 800<br>(2 700 руб./шт.) |
| Считыватель<br>HID Global<br>VertX EVO<br>V2000<br>(12 шт.) | - Масштабируемость (до 64 считывателей на один контроллер)<br>- Поддержка протокола OSDP (Open Supervised Device Protocol) | - Высокая стоимость оборудования<br>- Сложность настройки для | 19 200<br>(1 600 руб./шт.) |

|                               |                                                                                                                                                                                                                                                                  |                                |                            |
|-------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------|----------------------------|
|                               | - Интеграция с системами видеонаблюдения                                                                                                                                                                                                                         | неопытных пользователей        |                            |
| Кнопка АВК 805 А (1 шт.)      | АВК-805А — кнопка выхода, предназначенная для накладного способа установки. Светодиодная подсветка для использования в условиях недостаточной освещённости. Подходит для управления любыми замками: электромагнитными, электромеханическими и электроригельными. | Не выявлено                    | 1 700<br>(1 700 руб./шт.)  |
| Контроллер CASTLE RS (12 шт.) | Память 15000 ключей, поддержка двух интерфейсов TM/Wiegand                                                                                                                                                                                                       | Отсутствие корпуса в комплекте | 51 600<br>(4 300 руб./шт.) |

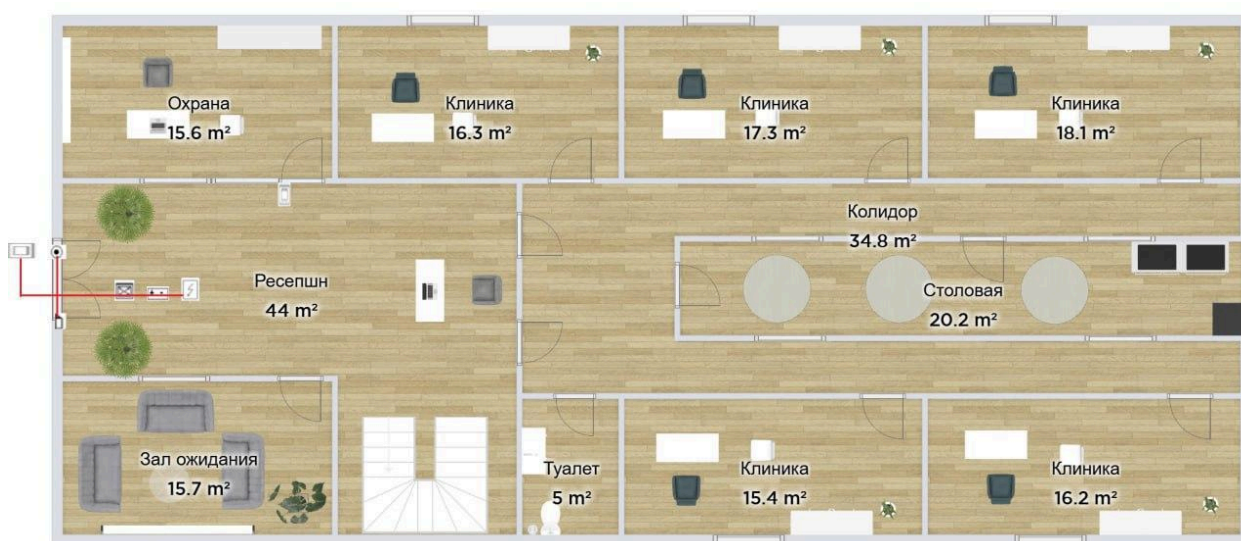


Рисунок 3 – План помещения с СКУД на первом этаже



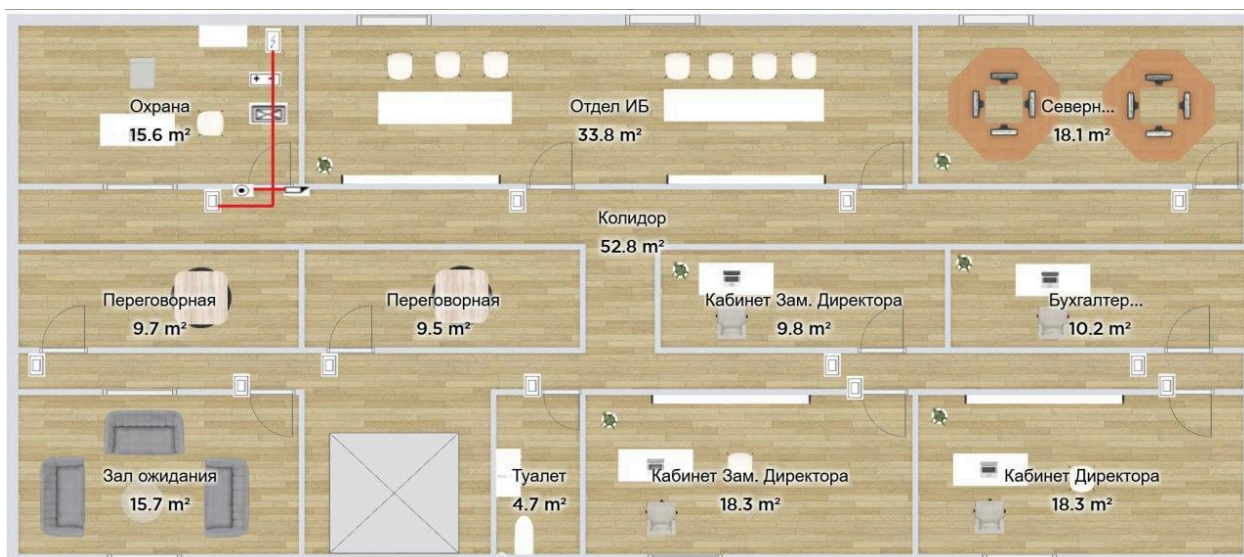


Рисунок 4 – План помещения с СКУД на втором этаже

Условные обозначения:

-  источники электропитания;
-  считыватель;
-  кнопка;
-  контроллер;
-  блочный щит управления.

Таблица 11 – 2

| Наименование средства                            | Достоинства                                                                                                                                                        | Недостатки                                                 | Финальная стоимость (руб.)  |
|--------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------|-----------------------------|
| Дымовой извещатель ИП 212-43М (ДИП-43М) (45 шт.) | Извещатели типа ИП212-43 защищены от проникновения насекомых внутрь корпуса и оптической системы мелкоячеистой (0,6×0,6 мм) металлической сеткой, что минимизирует | Время работы без замены батареи (CR123A) не более 5-7 лет. | 102 060<br>(2 268 руб./шт.) |

|                                                |                                                                       |                                                                                                                  |                            |
|------------------------------------------------|-----------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|----------------------------|
|                                                | возможность ложных срабатываний; диапазон рабочей температуры до +55. |                                                                                                                  |                            |
| Извещатель пожарный ручной ИПР 513-3АМ (4 шт.) | Потребление тока 0,5 мА; средний срок службы 10 лет.                  | Построена на коммутационной контактной схеме, может происходить окисление соответствующих элементов конструкции. | 8 404<br>(2 101 руб./шт.)  |
| Световое табло выход SLT Топаз 12 (4 шт.)      | Диапазон рабочей температуры от -30 до +55; степень защиты IP52.      | Потребление тока в дежурном режиме (световая индикация) 20 мА                                                    | 3 296<br>(824 руб./шт.)    |
| Маяк-12-КП Оповещатель светозвуковой (27 шт.)  | Уровень звукового давления 105 дБ; степень защиты IP55                | Регулировка громкости нет                                                                                        | 37 125<br>(1 375 руб./шт.) |

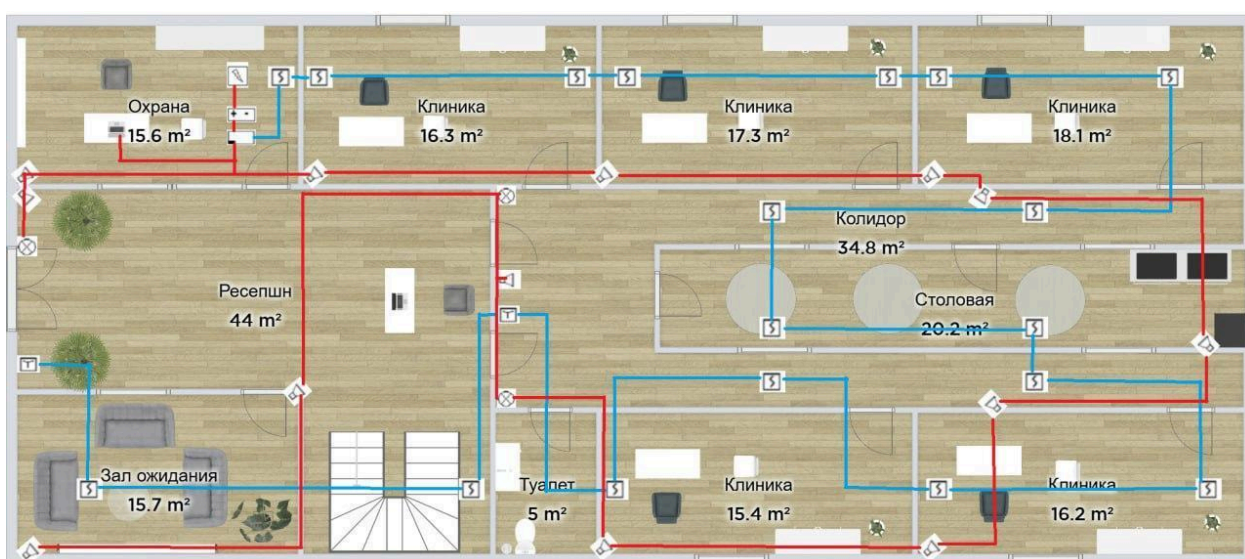


Рисунок 5 – План помещения с пожарно-охранной системой на первом этаже



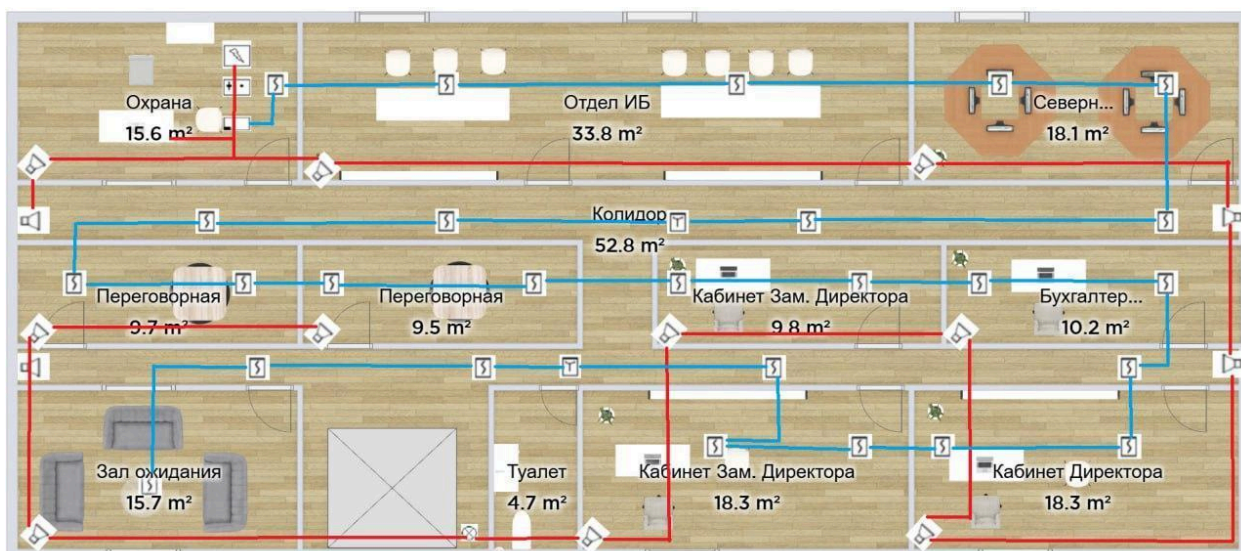


Рисунок 6 – План помещения с пожарно-охранной системой на втором этаже

Условные обозначения:

-  оповещатель звуковой пожарный;
-  извещатель пожарный дымовой;
-  извещатель пожарный световой;
-  блочный щит управления;
-  источник бесперебойного питания;
-  контрольно-приемное устройство;
-  извещатель пожарный ручной.

Таблица 12 – Сводная таблица по техническим средствам охраны

| Средство                        | Стоимость (руб.) |
|---------------------------------|------------------|
| Видеонаблюдение                 | 231 220          |
| СКУД                            | 137 300          |
| Пожарно – охранная сигнализация | 150 885          |

На представленные технические средства охраны необходимо выделить: 519 405 руб.

### 6.5. Криптографическая защита

Для дополнительного повышения уровня ИБ, не требуемого руководящими документами предлагается использовать криптографические средства защиты информации.

Таблица 13 – Криптографические средства

| Наименование средства | Достоинства                                                                                                                                                                                                                                                                                       | Недостатки                                                                                                                                                               | Финальная стоимость (руб.) |
|-----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|
| YubiKey 5             | <ul style="list-style-type: none"> <li>- Двухфакторная аутентификация (пароль и аппаратный ключ)</li> <li>- Возможность использования для различных сервисов и приложений</li> <li>- Простота в использовании</li> </ul>                                                                          | <ul style="list-style-type: none"> <li>- Высокая стоимость по сравнению с другими аутентификационными методами</li> <li>- Зависимость от поддержки сервисов</li> </ul>   | 5,000 руб./ед              |
| ViPNet CSP 4          | <p>Облегченная интеграция новых устройств с ViPNet CSP 4 за счет поддержки внешних устройств для создания и хранения ключей и сертификатов с использованием интерфейса PKCS#11</p> <p>Защищенная работа с веб-сервисами.</p> <p>Встраивание криптографических функций в сторонние приложения.</p> | <ul style="list-style-type: none"> <li>- Сложность в настройке для неопытных пользователей</li> <li>- Высокая стоимость полного пакета</li> </ul>                        | 8 000 руб./ед              |
| ViPNet Client 4       | <p>Высокая производительность шифрования и фильтрации трафика;</p> <p>Равный доступ к ресурсам;</p> <p>Защита канала не влияет на работу сторонних</p>                                                                                                                                            | <ul style="list-style-type: none"> <li>- Высокая стоимость внедрения и обслуживания</li> <li>- Возможность обхода фильтров в компоненте «Контроль приложений»</li> </ul> | 8 000 руб./ед              |

|  |                                        |  |  |
|--|----------------------------------------|--|--|
|  | приложений на компьютере пользователя. |  |  |
|--|----------------------------------------|--|--|

На основании анализа, проведенного в таблице 14, в качестве средства криптографической защиты выбрано VipNet Client для шифрования трафика и ViPNet CSP 4 для шифрования и контроля целостности данных.

Представленные меры соответствуют следующим требованиям по защите информации:

- ограничение доступа к информации, составляющей коммерческую тайну, путем установления порядка обращения с этой информацией и контроля за соблюдением такого порядка;
- необходимость внедрения правил использования криптографических средств ЗИ;

способствуют снижению вероятности реализации и риска ИБ следующих УБИ:

- угроза доступа к защищаемым файлам с использованием обходного пути;
- угроза внедрения кода или данных;
- угроза несанкционированного копирования защищаемой информации.

На представленные меры по защите информации необходимо выделить: 16 000 руб.

#### **6.6.Общая стоимость КСЗИ**

Таблица 14 – Итоговая стоимость КСЗИ

| Сфера защиты информации                   | Стоимость (руб.) |
|-------------------------------------------|------------------|
| Организационно-правовая защита информации | 170 000          |
| Программно-аппаратная защита информации   | 114 361          |
| Инженерно-техническая защита информации   | 66 200           |
| Технические средства охраны               | 519 405          |
| Криптографическая защита                  | 16 000           |

По результатам расчетов на комплексную систему защиты информации необходимо выделить: 885 966 руб.

## 7.ОЦЕНКА ЭФФЕКТИВНОСТИ ПРЕДЛОЖЕННЫХ МЕР

В результате применения предложенных мер и средств защиты в соответствии с требованиями РД удалось снизить вероятность следующих угроз:

Таблица 15 – Применения предложенных мер и средств защиты

| Мера/средство ЗИ        | Название УБИ                                                                                                      | Вероятность УБИ до применения, % | Вероятность УБИ после применения, % | Выполняемые требования РД                        |
|-------------------------|-------------------------------------------------------------------------------------------------------------------|----------------------------------|-------------------------------------|--------------------------------------------------|
| Программно-аппаратная   | Угроза использования слабостей криптографических алгоритмов и уязвимостей в программном обеспечении их реализации | 10,8                             | 3                                   | Использование антивирусного и анти-малварного ПО |
| Организационно-правовая | Угроза длительного удержания вычислительных ресурсов пользователями                                               | 11,4                             | 5                                   | Ограничение Ресурсов<br>Соблюдение сотрудниками  |
| Инженерно-техническая   | Угроза заражения DNS-кеша                                                                                         | 13,2                             | 10                                  | Подпись DNS-запросов (DNSSEC)                    |

|                                                        |                                                                             |      |    |                                                          |
|--------------------------------------------------------|-----------------------------------------------------------------------------|------|----|----------------------------------------------------------|
| Криптографическая<br>Инженерно-<br>техническая         | Угроза искажения вводимой и выводимой на периферийные устройства информации | 15,6 | 11 | Использование специализированного ПО "BitLocker"         |
| Организационно-правовая<br>Технические средства охраны | Угроза использования механизмов авторизации для повышения привилегий        | 9,4  | 7  | Контроль доступа к АРМ и серверам                        |
| Криптографическая<br>Инженерно-<br>техническая         | Угроза использования слабостей кодирования входных данных                   | 20   | 14 | Использование специализированного ПО                     |
| Криптографическая                                      | Угроза неправомерного ознакомления с защищаемой информацией                 | 16,4 | 13 | Использование специализированного ПО                     |
| Криптографическая<br>Технические средства охраны       | Угроза неправомерных действий в каналах связи                               | 20   | 8  | Использование специализированного ПО<br>Контроль доступа |

|                               |                                                                                                                                                                  |      |    |                                                                   |
|-------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|----|-------------------------------------------------------------------|
| Технические средства охраны   | Угроза несанкционированного доступа к активному и (или) пассивному виртуальному и (или) физическому сетевому оборудованию из физической и (или) виртуальной сети | 17,6 | 13 | Использование Сетевых Фильтров и Брандмауэров                     |
| Технические средства охраны   | Угроза определения топологии вычислительной сети                                                                                                                 | 17   | 10 | Использование Виртуальных Локальных Сетей (VLAN)                  |
| Организационно-правовая       | Угроза утраты носителей информации                                                                                                                               | 14   | 10 | Соблюдение сотрудниками инструкции, регламента                    |
| Программно-аппаратная         | Угроза внедрения кода или данных                                                                                                                                 | 19,8 | 17 | Использование антивируса                                          |
| Маршрутизатор и точки доступа | Угроза несанкционированного доступа к системе по беспроводным каналам                                                                                            | 29,8 | 19 | Настраиваемая маршрутизация, Аутентификация и управление доступом |

|                       |                                                |      |    |                                                            |
|-----------------------|------------------------------------------------|------|----|------------------------------------------------------------|
| Техническая           | Угроза преодоления физической защиты           | 22,8 | 17 | Контроль доступа(системы видеонаблюдения и аудита доступа) |
| Программно-аппаратная | Угроза «фишинга»                               | 22,6 | 15 | Использование антивируса                                   |
| Программно-аппаратная | Угроза маскирования действий вредоносного кода | 31,2 | 21 | Использование антивируса                                   |

Таблица 16 – Итоговая оценка рисков

| Идентификатор УБИ | Название УБИ                                                                                                      | Источник УБИ                                                                              | Риск до внедрения КСЗИ (руб.) | Риск после внедрения КСЗИ (руб.) |
|-------------------|-------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|-------------------------------|----------------------------------|
| УБИ.003           | Угроза использования слабостей криптографических алгоритмов и уязвимостей в программном обеспечении их реализации | Внешний нарушитель со средним потенциалом<br>Внутренний нарушитель со средним потенциалом | 108 000                       | 30 000                           |

|         |                                                                             |                                                                                           |         |         |
|---------|-----------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|---------|---------|
| УБИ.014 | Угроза длительного удержания вычислительных ресурсов пользователями         | Внешний нарушитель с низким потенциалом<br>Внутренний нарушитель с низким потенциалом     | 62 700  | 27 500  |
| УБИ.019 | Угроза заражения DNS-кеша                                                   | Внешний нарушитель с низким потенциалом                                                   | 59 400  | 45 000  |
| УБИ.027 | Угроза искажения вводимой и выводимой на периферийные устройства информации | Внешний нарушитель с высоким потенциалом<br>Внутренний нарушитель с низким потенциалом    | 78 000  | 55 000  |
| УБИ.031 | Угроза использования механизмов авторизации для повышения привилегий        | Внешний нарушитель с низким потенциалом<br>Внутренний нарушитель с низким потенциалом     | 103 400 | 77 000  |
| УБИ.033 | Угроза использования слабостей кодирования входных данных                   | Внешний нарушитель со средним потенциалом<br>Внутренний нарушитель со средним потенциалом | 200 000 | 140 000 |



|         |                                                                                                                                                                  |                                                                                           |         |         |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|---------|---------|
| УБИ.067 | Угроза неправомерного ознакомления с защищаемой информацией                                                                                                      | Внутренний нарушитель с низким потенциалом                                                | 180 400 | 143 000 |
| УБИ.069 | Угроза неправомерных действий в каналах связи                                                                                                                    | Внешний нарушитель с низким потенциалом                                                   | 220 000 | 88 000  |
| УБИ.073 | Угроза несанкционированного доступа к активному и (или) пассивному виртуальному и (или) физическому сетевому оборудованию из физической и (или) виртуальной сети | Внешний нарушитель со средним потенциалом<br>Внутренний нарушитель со средним потенциалом | 176 000 | 130 000 |
| УБИ.104 | Угроза определения топологии вычислительной сети                                                                                                                 | Внешний нарушитель с низким потенциалом                                                   | 374 000 | 220 000 |
| УБИ.156 | Угроза утраты носителей информации                                                                                                                               | Внутренний нарушитель с низким потенциалом                                                | 168 000 | 120 000 |
| УБИ.006 | Угроза внедрения кода или данных                                                                                                                                 | Внешний нарушитель с низким потенциалом                                                   | 326 700 | 280 500 |
| УБИ.083 | Угроза несанкционированного доступа к системе по беспроводным каналам                                                                                            | Внешний нарушитель с низким потенциалом                                                   | 298 000 | 190 000 |
| УБИ.139 | Угроза преодоления физической защиты                                                                                                                             | Внешний нарушитель со средним потенциалом                                                 | 250 800 | 187 000 |

|            |                                                |                                           |           |           |
|------------|------------------------------------------------|-------------------------------------------|-----------|-----------|
| УБИ.175    | Угроза «фишинга»                               | Внешний нарушитель с низким потенциалом   | 226 000   | 150 000   |
| УБИ.189    | Угроза маскирования действий вредоносного кода | Внешний нарушитель со средним потенциалом | 514 800   | 346 500   |
| Итого риск |                                                |                                           | 3 346 200 | 2 229 500 |

В соответствии с приведенными выше расчетами, итоговый риск снижен на **1 116 700 руб.**

На основе данных о доходах организации, приведенных в п.1.1, равными **3 500 000 руб/мес**, общей стоимости КСЗИ + пусконаладочные работы, указанной в п.6.6 и рассчитанной как **885 966 руб.**, полагаем затраты на представленную КСЗИ оправданными.

## **ЗАКЛЮЧЕНИЕ**

Мы узнали, как настроить систему безопасности компании, конкретно здесь мы возьмем пример компании MedCare. Кроме того, мы также узнаем больше о ценах на устройства и программное обеспечение, представленные сегодня на рынке, чтобы иметь возможность выбрать самые лучшие и подходящие устройства.